

Protection Mémoire, Credential Guard et Règles ASR

Objectifs :

- Comprendre en profondeur le fonctionnement du processus LSASS et les architectures d'attaque (Dumping, Injection).
- Maîtriser le concept de Processus Protégé (PPL - Protected Process Light).
- Architecture et implémentation de la Sécurité Basée sur la Virtualisation (VBS) et de Credential Guard.
- Déployer une défense comportementale via la Réduction de la Surface d'Attaque (ASR).

1. LSASS et des Attaques sur les Identifiants

Le service de sous-système de l'autorité de sécurité locale (*lsass.exe*) est la cible privilégiée des attaquants post-exploitation. Son rôle est de vérifier les connexions, gérer les changements de mots de passe et créer les jetons d'accès (Tokens).

1.1 Le stockage en mémoire vive (Le paradigme du SSO)

Pour garantir une expérience de Single Sign-On (SSO) fluide, LSASS fait appel à différents fournisseurs de sécurité (SSP - Security Support Providers) qui conservent des secrets en RAM.

- **WDigest** : Historiquement, conservait les mots de passe en clair (désactivé par défaut depuis Windows 8.1, mais réactivable par un attaquant via registre).
- **Kerberos** : Conserve les Tickets TGT (Ticket-Granting Tickets) et les clés de session.
- **MSV1_0 (NTLM)** : Conserve les empreintes (Hashs) NT, utilisées dans les attaques Pass-the-Hash.

1.2 Les méthodes d'extraction (Dumping)

Un attaquant disposant des privilèges Administrateur Local (ou SYSTEM) sur une machine utilise des outils (Mimikatz, ProcDump, ou des scripts PowerShell natifs) pour lire la mémoire de LSASS. La faille fondamentale réside dans le fait que, par défaut, le noyau Windows accorde le droit **PROCESS_ALL_ACCESS** (incluant **PROCESS_VM_READ**) à n'importe quel processus lancé en tant qu'Administrateur qui demande à lire *lsass.exe*.

2. Niveau 1 : LSA Protection (RunAsPPL)

Pour contrer cette lecture libre de la mémoire, Microsoft a introduit le concept de **PPL** (**Protected Process Light**).

2.1 Le modèle de confiance du Noyau

Lorsqu'un processus est défini comme "Protégé" (PPL), le gestionnaire d'objets du noyau Windows refuse formellement l'accès à ce processus à tout autre processus qui ne possède pas un certificat de signature numérique spécifique émis par Microsoft.

- **Sans PPL** : Mimikatz (même non signé) demande à lire LSASS → Le noyau accepte (car l'utilisateur est admin).
- **Avec PPL** : Mimikatz demande à lire LSASS → Le noyau vérifie la signature de Mimikatz → Signature non valide (ou absente) → Le noyau renvoie **Access Denied** (Erreur 5), même si Mimikatz tourne en **SYSTEM**.

3. Credential Guard (VBS)

Pour parer à la faiblesse d'une protection logicielle, l'ANSSI impose pour les actifs critiques (Tier 0 / Tier 1) le déploiement de **Credential Guard**. C'est un changement architectural majeur qui repose sur la virtualisation matérielle (VBS - Virtualization-Based Security).

3.1 Architecture de l'Hyperviseur (Ring -1)

Avec Credential Guard, l'OS Windows que vous voyez n'est plus le maître absolu du matériel. Un hyperviseur minimaliste (Hyper-V) s'installe en dessous de Windows (au niveau Ring -1).

Windows est divisé en deux mondes :

1. **Le VTL 0 (Virtual Trust Level 0)** : C'est le Windows normal (Noyau + Espace Utilisateur).
2. **Le VTL 1 (Le mode sécurisé)** : Un micro-conteneur ultra-sécurisé géré par l'hyperviseur, totalement inaccessible depuis le VTL 0.

3.2 Le cloisonnement des secrets (LSAIsolation)

Lors de l'activation de Credential Guard :

1. Les secrets (Hashs NTLM, Tickets Kerberos) sont retirés de **lsass.exe** (VTL 0).
2. Ils sont stockés dans un nouveau processus appelé **LSAIsolation.exe** (LSA Isolé), qui s'exécute dans le VTL 1.
3. Le **lsass.exe** classique devient un simple facteur (un Proxy). Lorsqu'une authentification est requise, il envoie une requête RPC chiffrée au VTL 1. LSAIsolation effectue le calcul mathématique dans son coffre-fort et ne renvoie que le résultat (Oui/Non) à **lsass.exe**.

Impact de sécurité : Même si l'attaquant charge un rootkit noyau (Ring 0) sur Windows, il ne peut pas lire la mémoire du VTL 1, car le processeur matériellement (via les instructions Intel VT-x / AMD-V) lui en interdit l'accès. Le "Pass-the-Hash" devient architecturalement impossible.

4. La Défense Comportementale : Les Règles ASR

Les solutions EDR et Antivirus traditionnels échouent face aux techniques "Living off the Land" (LotL). Pour combler ce vide, Windows Defender intègre la **Réduction de la Surface d'Attaque (ASR - Attack Surface Reduction)**.

4.1 Le concept de l'ASR

Les règles ASR ne cherchent pas un malware, elles **interdisent un comportement métier dangereux**. L'objectif est de bloquer techniquement des actions qui sont souvent utilisées par les attaquants mais très rarement par les utilisateurs normaux.

4.2 Les GUIDs Critiques (Recommandations ANSSI)

Les règles ASR sont identifiées par des GUID (Identifiants Uniques) et pilotables par GPO. Les règles les plus critiques à déployer sont :

- **Bloquer le vol d'informations d'identification dans LSASS :**
9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2 (C'est la couche de défense complémentaire si Credential Guard n'est pas activable sur d'anciens matériels).
- **Bloquer les processus enfants issus d'Office :**
d4f940ab-401b-4efc-aadc-ad5f3c50688a (Un document Word n'a aucune raison légitime de lancer *powershell.exe* ou *cmd.exe*. Cette règle tue 90% des Macros malveillantes).
- **Bloquer l'exécution de code à partir de clés USB :**
b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4.
- **Bloquer le vol de mots de passe par les processus non signés :** Limite les techniques de Scraping de mémoire.

Méthodologie de déploiement : À l'instar d'AppLocker, les règles ASR disposent d'un **Mode Audit** (*Valeur = 2*). Elles doivent obligatoirement être déployées en écoute passive pendant plusieurs semaines pour identifier d'éventuels faux positifs liés à des applications métiers exotiques, avant d'être passées en **Mode Blocage** (*Valeur = 1*).